

NOTE 1 This standard is part of series of standards that addresses the issue of security for industrial automation and control systems (IACS). It has been developed by working group 4, task group 2 of the IEC99 committee in cooperation with IEC TC65/WG10. This document prescribes the security requirements for control systems related to the seven foundational requirements defined in IEC 62443 - 1 and assigns system security levels (SLs) to the system under consideration (SuC).

NOTA 2 El formato de esta norma sigue los requisitos ISO/IEC discutidos en las Directivas ISO/IEC, Parte 2 [11]. 1 Estas directivas especifican el formato de la norma, así como el uso de términos como "deberá", "deberá" y "podrá". Los requisitos especificados en las cláusulas normativas utilizan las convenciones discutidas en el Apéndice H de las Directivas ISO/IEC.

Las organizaciones de sistemas de control y automatización industrial (IACS) utilizan cada vez más dispositivos comerciales en red (COTS) que son económicos, eficientes y altamente automatizados. Los sistemas de control también están cada vez más interconectados con redes que no son IACS por razones comerciales válidas. Estos dispositivos, las tecnologías de redes abiertas y la mayor conectividad brindan una mayor oportunidad de sufrir ataques cibernéticos contra el hardware y el software del sistema de control. Esa debilidad puede tener consecuencias para la salud, la seguridad y el medio ambiente (HSE), financieras y/o de reputación en los sistemas de control implementados.

Es posible que las organizaciones que implementan soluciones de seguridad cibernética de tecnología de la información (TI) empresarial para abordar la seguridad de IACS no comprendan completamente los resultados de esta decisión. Si bien muchas aplicaciones de TI y soluciones de seguridad empresariales se pueden aplicar a IACS, es necesario aplicarlas de manera adecuada para eliminar consecuencias involuntarias. Por esta razón, el enfoque utilizado para definir los requisitos del sistema debe basarse en una combinación de requisitos funcionales y evaluación de riesgos, incluyendo a menudo también una conciencia de los problemas operativos.

Las medidas de seguridad del SIGC no deberían tener el potencial de causar la pérdida de servicios y funciones esenciales, incluidos los procedimientos de emergencia. (Las medidas de seguridad de TI, como se implementan a menudo, tienen este potencial). Los objetivos de seguridad de IACS se centran en la disponibilidad del sistema de control, la protección de la planta, las operaciones de la planta (incluso en un modo degradado) y la respuesta del sistema en momentos críticos. Los objetivos de seguridad de TI a menudo no ponen el mismo énfasis en estos factores; Es posible que estén más preocupados por proteger la información que los activos físicos. Estas diferentes metas deben establecerse claramente como objetivos de seguridad, independientemente del grado de integración de la planta logrado. Un paso clave en la evaluación de riesgos, según lo exige IEC 62443 - 2 - 1 2, debería ser la identificación de qué servicios y funciones son realmente esenciales para las operaciones. (Por ejemplo, en algunas instalaciones se puede determinar que el soporte de ingeniería es un servicio o función no esencial). En algunos casos, puede ser aceptable que una acción de seguridad cause la pérdida temporal de un servicio o función no esencial, a diferencia de un servicio o función esencial que no debería verse afectado negativamente.

Este estándar supone que se ha establecido un programa de seguridad y se está operando de acuerdo con IEC 62443 - 2 - 1. Además, se supone que la administración de parches se implementa de manera consistente con las recomendaciones detalladas en IEC / TR 62443 - 2 - 3 [5] utilizando los requisitos del sistema de control apropiados y las mejoras de requisitos como se describe en este estándar. Además, IEC 62443 - 3 - 2 [8] describe cómo un proyecto define niveles de seguridad basados en riesgos (SL) que luego se utilizan para seleccionar productos con las capacidades técnicas de seguridad adecuadas como se detalla en esta norma. Los aportes clave a este estándar incluyeron ISO/IEC 27002 [15] y NIST SP800-53, rev 3 [24] (consulte la Cláusula 2 y la Bibliografía para obtener una lista más completa del material fuente).

El objetivo principal de la serie IEC 62443 es proporcionar un marco flexible que facilite abordar las vulnerabilidades actuales y futuras en IACS y aplicar las mitigaciones necesarias de una manera sistemática y defendible. Es importante comprender que la intención de la serie IEC 62443 es crear extensiones para la seguridad empresarial que adapten los requisitos de los sistemas de TI empresariales y los combinen con los requisitos únicos para una fuerte disponibilidad que necesita IACS.

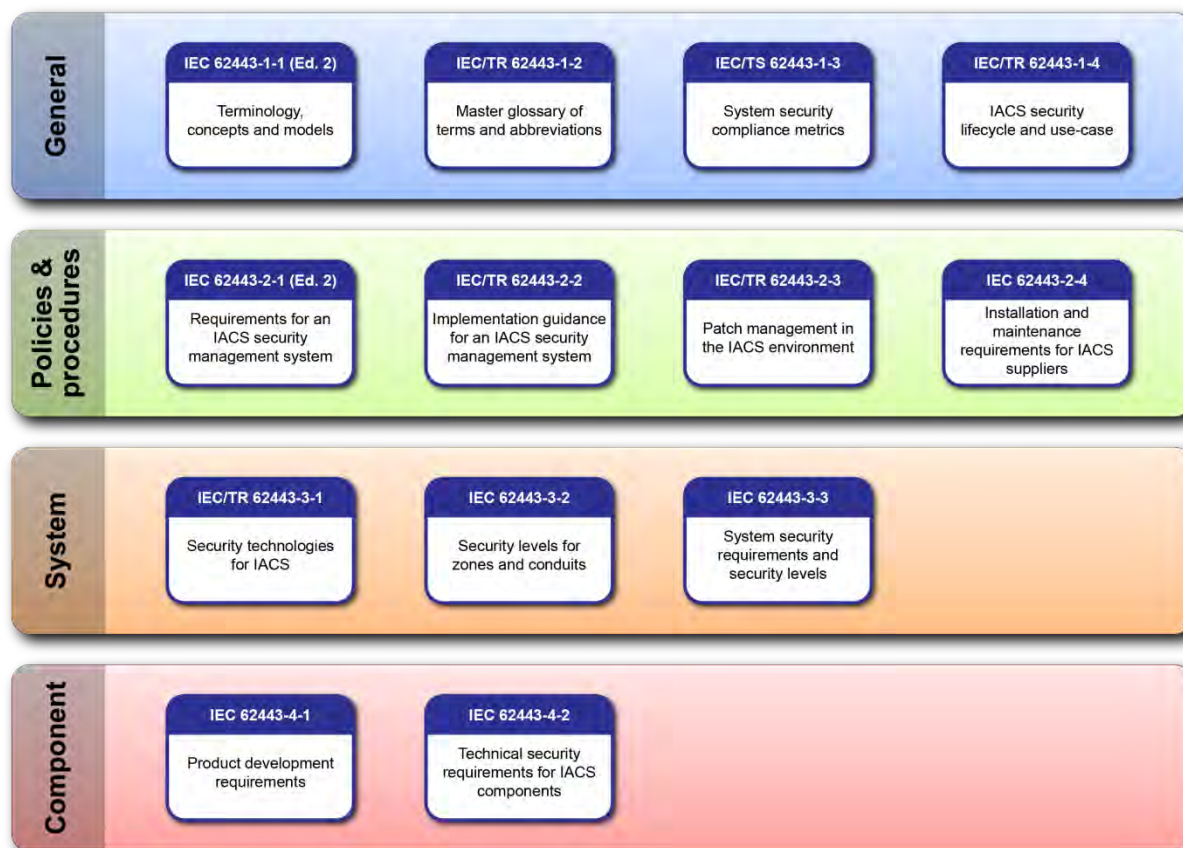
La audiencia de la comunidad IACS para este estándar está destinada a propietarios de activos, integradores de sistemas, proveedores de productos, proveedores de servicios y, cuando corresponda, autoridades de cumplimiento. Las autoridades de cumplimiento incluyen agencias gubernamentales y reguladores con autoridad legal para realizar auditorías para verificar el cumplimiento de las leyes y regulaciones vigentes.

System integrators, product suppliers and service providers will use this standard to evaluate whether their products and services can provide the functional security capability to meet the asset owner's target security level (SL-T) requirements. As with the assignment of SL-Ts, the applicability of individual control system requirements (SRs) and requirement enhancements (REs) needs to be based on an asset owner's security policies, procedures and risk assessment in the context of their specific site. Note that some SRs contain specific conditions for permissible exceptions, such as where meeting the SR will violate fundamental operational requirements of a control system (which may trigger the need for compensating countermeasures).

When designing a control system to meet the set of SRs associated with specific SL-Ts, it is not necessary that every component of the proposed control system support every system requirement to the level mandated in this standard. Compensating countermeasures can be employed to provide the needed functionality to other subsystems, such that the overall SL-T requirements are met at the control system level. Inclusion of compensating countermeasures during the design phase should be accompanied by comprehensive documentation so that the resulting achieved control system SL, SL-A(control system), fully reflects the intended security capabilities inherent in the design. Similarly, during certification testing and/or post-installation audits, compensating countermeasures can be utilized and documented in order to meet the overall control system SL.

There is insufficient detail in this standard to design and build an integrated security architecture. That requires additional system-level analysis and development of derived requirements that are the subject of other standards in the IEC 62443 series (see 0). Note that providing specifications detailed enough to build a security architecture are not the goal of this standard. The goal is to define a common, minimum set of requirements to reach progressively more stringent security levels. The actual design of an architecture that meets these requirements is the job of system integrators and product suppliers. In this task, they retain the freedom to make individual choices, thus supporting competition and innovation. Thus this standard strictly adheres to specifying functional requirements, and does not address how these functional requirements should be met.

IEC 62443 - 3 - 2 utiliza los SR y RE como lista de verificación. Después de que el sistema bajo consideración (SuC) se haya descrito en términos de zonas y conductos, y se hayan asignado SL objetivo individuales a estas zonas y conductos, los SR y RE en esta norma, así como su asignación a SL de capacidad (SL-C), se utilizan para compilar una lista de requisitos que el diseño del sistema de control debe cumplir. Luego se puede comprobar la integridad de un diseño de sistema de control determinado, proporcionando así los SL-A.



IEC / TS 62443 - 1 - 3 [2] utiliza los requisitos fundamentales (FR), SR, RE y el mapeo de SL-C como una lista de verificación para probar la integridad de la especificación de métricas cuantitativas. Las métricas cuantitativas de cumplimiento de seguridad son específicas del contexto. Junto con IEC 62443 - 3 - 2, las asignaciones SL-T del propietario del activo se traducen en métricas cuantitativas que se pueden utilizar para respaldar el análisis del sistema y diseñar estudios de compensación para desarrollar una arquitectura de seguridad.

IEC 62443 - 4 - 1 [9] aborda los requisitos generales durante el desarrollo de productos. Como tal, IEC 62443 - 4 - 1 se centra en el proveedor de productos. Los requisitos de seguridad del producto se derivan de la lista de requisitos básicos y RE especificados en esta norma. Las especificaciones de calidad normativas de IEC 62443 - 4 - 1 se utilizarán al desarrollar las capacidades de estos productos.

IEC 62443 - 4 - 2 [10] contiene conjuntos de requisitos derivados que proporcionan una asignación detallada de los SR especificados en esta norma a los subsistemas y componentes del SuC. En el momento en que se redactó esta norma, las categorías de componentes abordadas en IEC 62443 - 4 - 2 eran: dispositivos integrados, dispositivos host, dispositivos de red y aplicaciones. Como tal, IEC 62443 - 4 - 2 se centra en el proveedor (proveedor de productos y proveedor de servicios). Los requisitos de seguridad del producto se derivan primero de la lista de requisitos básicos y RE especificados en esta norma. Los requisitos y métricas de seguridad de IEC 62443 - 3 - 2 e IEC / TS 62443 - 1 - 3 se utilizan para perfeccionar estos requisitos normativos derivados.